

NutriAgent — Week 11 Final Viva Prep Guide

SLIIT IT3041 Information Retrieval & Web Analytics | 20 Marks Master Preparation Guide

Viva Evaluation Rubric Criteria (20 Marks Total)	Core Focus & Key Deliverables
1. Technical Depth	Architectural soundness, algorithms (spaCy NLP, vector search, Gemini Flash), cryptographic security, and schema robustness.
2. Individual Contribution	Clear defense of individual agent ownership: Security (Mem 1), Intake (Mem 2), IR (Mem 3), Planning (Mem 4).
3. Communication Protocols	Chained synchronous HTTP microservices, shared Pydantic contract, distributed UUID4 X-Trace-ID tracing, and HTTP error semantics.
4. Responsible AI Practices	Grounded retrieval avoiding hallucination, deterministic allergen safety shields, dynamic condition disclaimers, and injection defense.
5. Commercialization & Pricing	B2C Freemium & B2B Clinic SaaS, token unit economics (\$0.0005/plan), cloud container costs, and pricing tiers.

1. Individual Contributions & Deep Technical Defense

Each team member owns one autonomous microservice agent running in its own process. In the viva, each member must speak with full technical authority on their own service while understanding how it fits into the synchronous chain.

Member 1: Security & Validation Agent (Gateway · Port 8001)

- **Core Role:** Acts as the public reverse-proxy gateway and Zero-Trust perimeter. All external requests enter port 8001; internal agents (8002, 8003, 8004) are shielded behind this gateway.
- **Authentication Architecture:** Backed by SQLite (nutriagent.db) using **PBKDF2-HMAC-SHA256** with unique cryptographic salts (310,000 iterations). Protects against rainbow tables and brute-force attacks. Generates stateless cryptographically signed **JWTs (HS256)** with 30-minute expiration.
- **Universal Prompt Injection & Jailbreak Guard:** Multi-layered regex engine detecting instruction overrides ('ignore previous instructions'), persona hijacking ('DAN mode', 'act as unrestricted agent'), system prompt leakage, delimiter impersonation, and Unicode de-obfuscation / leetspeak mapping (@ -> a, 0 -> o).
- **Administrative & Destructive Command Defense:** Dedicated filter intercepting destructive commands (delete user, drop database, remove account, truncate table, kill process, rm -rf) with zero false-positives on legitimate nutrition text.
- **Rate Limiting & Distributed Tracing:** SlowAPI client-IP quota enforcement (5 login/min, 10 query/min). Generates and propagates canonical UUID4 X-Trace-ID across all agents without altering JSON payload bodies.
- **Unified Web Chat Workspace:** Built a responsive dark-mode AI Chat client with live multi-agent pipeline animated progress, macro pills, culinary drawers, and audit log inspection modal.

Likely Viva Questions for Member 1:

Q: Why do you validate authentication before checking input text?

Answer: Evaluating regexes on untrusted, unauthenticated input opens the gateway to Regular Expression Denial of Service

(ReDoS) or resource exhaustion. Authenticating first ensures compute-heavy validation runs only for verified users.

Q: How does your system block 'delete user' without blocking 'I want to delete sugar from my diet'?

Answer: We use context-targeted regexes that specifically pair destructive verbs (delete, drop, remove, purge) with administrative nouns (user, account, table, database, system). It matches `\bdelete\s+user\b` but allows delete sugar or drop body fat.

Q: Why strip the JWT before forwarding to the Intake Agent?

Answer: Principle of Least Privilege and Attack Surface Reduction. Downstream microservices are internal and only need the verified user ID and sanitized prompt. Forwarding tokens internally risks token leakage in internal logs or intermediary microservices.

Member 2: Intake & Profile Agent (Port 8002)

- **Core Role:** Natural Language Understanding (NLU) service that transforms unstructured, noisy user prompts into a validated Pydantic UserProfile object.
- **spaCy EntityRuler Pipeline:** Employs a custom spaCy EntityRuler pattern matcher over 5 clinical taxonomy categories: **Allergies** (9 types: peanut, tree nuts, shellfish, dairy, gluten, etc.), **Conditions** (diabetes, hypertension, celiac, kidney disease, lactose intolerance), **Goals** (weight loss, muscle gain, maintenance, general health), **Diet Types** (vegan, vegetarian, keto, pescatarian, halal), and **Preferences** (high protein, low carb, low sodium, quick meals).
- **Contextual Windowed Negation Handling:** Implements regex lookbehind analysis (`_is_negated`) to prevent false positives when users deny a condition (e.g. *'I have no dairy allergy'* or *'don't have an allergy to eggs'* is correctly discarded).
- **Calorie Target Numerical Extraction:** Regex boundary parser capturing quantitative energy goals (e.g. *'about 2200 kcal'*, *'under 1600 calories'*, *'no more than 2000 cals'*).
- **SQLite Persistence Store (profiles.sqlite3):** Automatically persists user profiles and merges incremental updates (`merge_profiles`), allowing returning users to ask one-off queries (*'suggest a healthy lunch'*) while retaining past medical constraints.

Likely Viva Questions for Member 2:

Q: Why use spaCy EntityRuler instead of a generic LLM prompt to extract profiles?

Answer: Determinism, latency, and cost. EntityRuler executes in under 2 milliseconds on CPU with 100% deterministic entity extraction, zero hallucination, and no token costs. It guarantees that critical medical allergies are never randomly omitted by non-deterministic LLMs.

Q: How do you handle returning users who change their mind?

Answer: Our `classify_intent()` function detects profile update triggers (e.g. *'instead'*, *'update'*, *'now'*). When detected, `merge_profiles()` overwrites existing fields (like diet type) while preserving previously declared persistent facts like chronic allergies.

Member 3: Nutrition Information Retrieval (IR) Agent (Port 8003)

- **Core Role:** Information Retrieval engine providing grounded nutritional truth. Shields the system from LLM nutritional hallucination by serving real, verified food records.
- **Dense Vector Embeddings:** Encodes user food queries into 384-dimensional dense semantic vector space using the sentence-transformers model (all-MiniLM-L6-v2).
- **ChromaDB Vector Store:** Indexes USDA FoodData Central and curated whole-food recipe datasets (foods.csv, epi_r.csv) in a persistent ChromaDB instance.
- **Deterministic Hard-Filtering Safety Layer:** Applies strict boolean set-exclusion filters for all user allergies (e.g., completely dropping any food containing peanut, dairy, or shellfish ingredients) regardless of how high its vector similarity score is.

- **Nutritional Fact Grounding:** Attaches verified calories, protein (g), carbohydrates (g), fat (g), and source attribution to every retrieved food item sent to the Planning Agent.

Likely Viva Questions for Member 3:

Q: Why do vector similarity search and then apply hard filtering, instead of just filtering?

Answer: Vector search finds semantically relevant items that match user tastes and goals (e.g. 'comfort food' or 'high protein dinner'). However, vector distance is probabilistic. To ensure 100% life-critical patient safety, deterministic hard filtering must strictly eliminate allergens after retrieval.

Q: What happens if the query matches no safe foods in the database?

Answer: The IR Agent returns an empty items list []. Downstream, the Planning Agent detects this and gracefully explains that no foods safely satisfy both the calorie targets and strict allergen constraints, preventing dangerous fallbacks.

Member 4: Meal Planning & Reasoning Agent (Port 8004)

- **Core Role:** Reasoning engine that transforms retrieved grounded foods and user clinical constraints into an empathetic, actionable, and explainable meal plan.
- **Google Gemini Generative AI Integration:** Integrates Google's google-genai SDK utilizing Gemini Flash models (gemini-2.5-flash, gemini-2.0-flash) with strict schema validation against the Pydantic MealPlan schema.
- **Strict Grounding Constraints:** System prompt strictly forbids the model from inventing foods, modifying calorie numbers, or adding unretrieved ingredients. It reasons ONLY over the provided retrieved_items.
- **Culinary Enrichment & Recipes:** Generates whole-food ingredient breakdowns and actionable Chef's prep_tip for cooking, seasoning, and meal-prep.
- **Sharp Allergen Safety Shield:** Generates explicit allergen_safety_note certifying that the meal is 100% free of the user's declared allergies, providing peace of mind.
- **Dynamic Condition-Tailored Disclaimers:** Replaces static disclaimers with generate_dynamic_disclaimer(), generating targeted medical guidance (e.g., sodium restriction for hypertension, glycemic indexing for diabetes, cross-contamination warnings for celiac disease).
- **Synchronized Resilient Fallback Engine:** Deterministic rule-based fallback planner that operates with full recipe tips, macros, and disclaimers if offline or when API quotas are exhausted.

Likely Viva Questions for Member 4:

Q: How do you prevent Gemini from hallucinating inaccurate calories?

Answer: Our prompt explicitly passes retrieved nutrition facts as immutable data and instructs the model to copy calories and macros verbatim. Furthermore, our post-processing validator cross-checks the LLM output against the original retrieved items before sending it back.

Q: Why do you have dynamic disclaimers instead of a single static disclaimer?

Answer: Responsible AI and patient-centric safety. A diabetic patient requires warnings regarding carbohydrate monitoring and insulin therapy, whereas a hypertension patient needs low-sodium advice. Tailoring disclaimers provides medically accurate context without giving illegal medical diagnoses.

2. Understanding of Communication Protocols (Rubric Item 3)

NutriAgent adopts a **Synchronous Chained HTTP Microservices Pattern** over RESTful JSON APIs. Below are the key architectural decisions you must defend in the viva:

Protocol Aspect	NutriAgent Implementation	Architectural Justification
Communication Style	Synchronous chained HTTP (Client -> Sec -> Intake -> IR -> Planning -> Return)	The user is waiting in real-time in the Chat UI. Synchronous chaining provides immediate feedback without the operational overhead of message queues.
Shared Schema Contract	shared/schemas.py imported by all 4 agents	Single Source of Truth. Eliminates schema drift between independently developed microservices.
Distributed Tracing	HTTP Header: X-Trace-ID (canonical UUID4)	Enables end-to-end request correlation across all 4 independent logs without modifying JSON payload schemas.
Security Boundary	Gateway terminates auth; forwards plaintext user_id and raw_text	Downstream agents remain stateless and decoupled from user credential management.
Error Code Semantics	400 (Bad input), 401 (Auth fail), 403 (Mismatch), 422 (Schema err), 429 (Rate limit), 502 (Downstream fail), 504 (Timeout)	Standardized HTTP status codes allow frontends and gateways to handle network, security, and application errors deterministically.

3. Explanation of Responsible AI Practices (Rubric Item 4)

Responsible AI is a primary evaluation pillar for health-related AI applications. NutriAgent embeds safety into every microservice layer:

- **1. Hallucination Prevention via Grounded Retrieval:** Standard LLMs hallucinate nutritional numbers. NutriAgent forces the Planning Agent to recommend *only* items retrieved and verified by the Nutrition IR Agent from real datasets (USDA). The LLM's role is restricted to reasoning and culinary explanation, not data creation.
- **2. Life-Critical Allergen Safety Guardrails:** Allergies can be fatal (anaphylaxis). We do not trust probabilistic LLM reasoning to filter out allergens. Instead, the IR Agent executes deterministic boolean filtering, and the Planning Agent provides an explicit allergen_safety_note certifying zero cross-contamination risk.
- **3. Ethical & Legal Boundaries (Dynamic Medical Disclaimers):** NutriAgent is an AI advisor, not a licensed medical doctor. Every recommendation concludes with a tailored health disclaimer explaining that advice does not supersede professional medical supervision, customized to specific chronic conditions (diabetes, hypertension, celiac).
- **4. Adversarial Attack & Jailbreak Resistance:** The Security Gateway filters prompt injection, persona hijackings (DAN mode), instruction overrides, and administrative command attacks (delete user), preventing the model from generating unsafe or toxic advice.
- **5. Privacy & Data Minimization:** Passwords are protected using salted PBKDF2 hashing. Structured request logs redact PII, tokens, and health queries. Only UUID4 trace IDs and latency metrics are recorded.

4. Commercialization & Pricing Discussion (Rubric Item 5)

In the viva, examiners evaluate whether the team understands real-world viability, cloud infrastructure costs, API unit economics, and monetization strategies.

Cost Category	Unit / Monthly Cost	Estimated Impact on Margin
Gemini 2.0 Flash API	\$0.10 / 1M input tokens \$0.40 / 1M output tokens	< \$0.0005 per meal plan generated! Incredibly high gross margin (>95%).
Microservice Hosting	Containerized on AWS ECS Fargate or Google Cloud Run (~\$35/month)	Scales to zero when idle; auto-scales up during peak meal planning hours.
ChromaDB Vector Store	Chroma Cloud or persistent AWS EBS volume (~\$15/month)	Extremely cost-effective for whole-food catalog embeddings.

Tier	Price	Target Audience & Included Features
Free Tier	\$0 / month	3 meal plans / day, basic calorie and allergen filtering. Acts as consumer acquisition funnel.
Pro Tier (B2C)	\$9.99 / mo or \$79 / yr	Unlimited meal plans, Chef's recipe preparation tips, macro breakdown pills, family allergen profiles, and exportable grocery lists.
Clinic / Dietitian Tier (B2B)	\$99.00 / mo per practitioner	Dietitian dashboard, patient EHR integration, custom clinical nutrition constraints, audit logs, and branded PDF exports for clinic patients.

Viva Tip for Commercialization:

When asked 'How does NutriAgent beat MyFitnessPal or generic ChatGPT?', answer:

- 1. Safety vs. Hallucination:** ChatGPT hallucinates nutrition numbers and has caused allergic reactions; NutriAgent grounds all numbers in verified USDA datasets.
- 2. Personalized Clinical Tailoring:** MyFitnessPal is a manual calorie logger; NutriAgent is an active multi-agent AI advisor that creates actionable, chef-guided meal plans tailored to specific health conditions.